OWASP SEOUL

보안 엔지니어의 장바구니 채우기

보안 제품을 잘 고르고, 잘 사고, 잘 쓰는 것도 실력이다



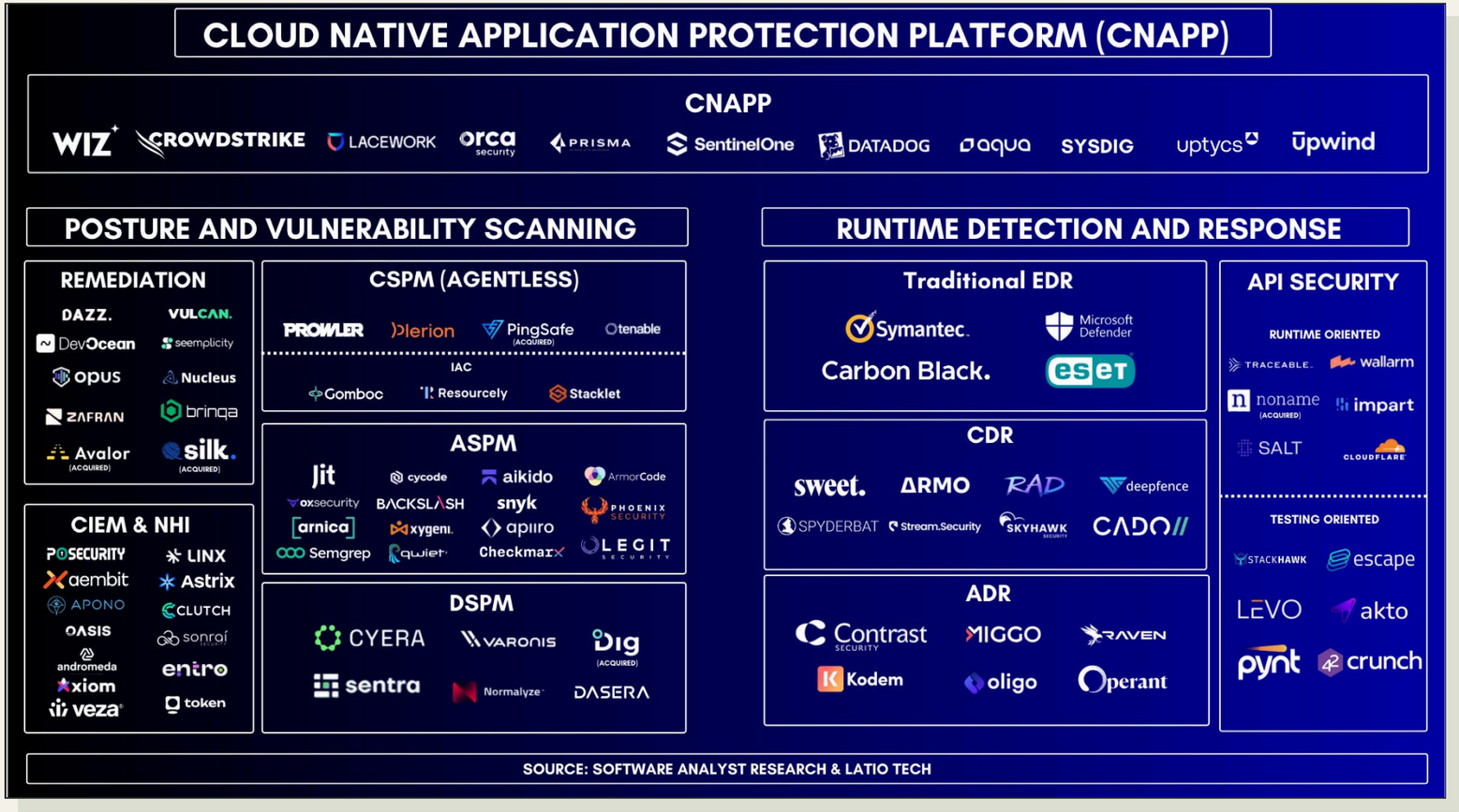
HYUNDAI AutoEver

박건호 / 현대오토에버

HYUNDAI AUTOEVER Corp. · Cloud Security Engineer

TOO MANY OPTIONS

클라우드 보안 제품, 몇 개나 될까요?



출처: SACR & Latio Tech, Redefining CNAPP (2024) ↗

WHAT THE RESEARCH SAYS

더 사는데, 덜 만족합니다.

지출 ↑ 만족 ↓

클라우드 보안 예산은 늘지만
실사용자는 여전히 불만족

기능 과잉

기능 수요는 커지는데,
잘 되는 플랫폼은 오히려 기능이 적다

도구는 많고 결과는 적다

맥락 없는 알림, 알림 피로,
많은 도구와 알림을 감당하는 작은 운영팀

문제는 살 것이 없어서가 아니라, 무엇을 사야 할지 판단하기 어려워서입니다.

SACR & James Berthoty, Redefining CNAPP (2024) · Key Actionable Summary의 문제의식 요약 ↗

THREE CRITERIA

무엇을 기준으로
고르고, 사고, 써야 할까요?

01

잘 고르기

우리 환경에 맞는지
제품의 성분표를 직접 작성한다

02

잘 사기

가격표가 아니라
영수증 전체를 본다

03

잘 쓰기

기능 목록이 아니라
운영 결과로 증명한다

01

잘 고르기

우리 환경에 맞는지, 제품의 성분표를 직접 작성한다.

BEFORE YOU ADD TO CART

장바구니에 담기 전에, 기능과 구조를 봅니다.

기능 · 우리에게 맞는가

PAIN POINT	**원래 풀려던 문제가 무엇이었나?** 기능 목록이 아니라 우리 페인포인트에서 출발
API	**콘솔 밖에서도 다 되는가?** 조회부터 조치까지 자동화할 수 있는지
DOCS	**제품 문서화가 잘 되어 있는가?** API 레퍼런스·필요 권한·로그 스키마·변경 이력
INTEGRATION	**우리 흐름에 매끄럽게 통합되는가?** SIEM·SOAR·IdP·티켓·클라우드 네이티브 서비스

구조 · 어떻게 붙어서 돌아가는가

TOUCHPOINT	**우리 환경과 어디서 만나는가?** 에이전트·API·교차 계정 역할·네트워크·장비, 로그 경로
DEPLOYMENT	**SaaS인가, 설치형인가?** 데이터 저장 위치, 운영·패치 책임, 장애 시 영향
ACCESS	**관리자 권한을 나눌 수 있는가?** 조회·조치 역할 분리, SSO 연동, 감사 로그
DATA	**무엇을 가져가고 얼마나 두는가?** 수집 범위, 보존 기간, 외부 유출 접점

데모에서 본 것은 포장지처럼 기대로만 두고, 우리 환경에서 확인한 것만 성분표로 작성합니다.

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

WHO RUNS IT

누가, 얼마나 운영할지까지가 고르기입니다.

역할	제품 안의 권한	맡는 일	업무 빈도
보안 관제	조회 · 알림 처리	알림 분류 · 1차 판단	상시
보안 엔지니어	규칙 · 자동화 설정	탐지 튜닝 · 연동 유지보수	주 단위
인프라 담당	에이전트 · 역할 배포	배포 · 업데이트 · 장애 대응	변경 시
서비스 담당	조치 승인 · 예외 요청	조치 확인 · 예외 사유 관리	건별

RnR과 인원별 공수가 그려지지 않으면, 좋은 제품도 켜 놓은 대시보드로 끝납니다.

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

CASE · ONE-PAGE SUMMARY

고르는 과정의 끝은,
한 장의 성분표와 가격표입니다.

선택지	얻는 것	포기하는 것	비용
클라우드 네이티브	이미 쓰는 권한·로그 위에서 바로 시작	클라우드마다 따로 보고 따로 운영	켜면 끝?
서드파티 플랫폼	여러 클라우드를 한 화면, 같은 기준으로	새 에이전트·새 콘솔, 익숙해질 시간	라이선스가 전부?
오픈소스 · 직접 구축	라이선스 없이 필요한 만큼 고쳐 쓰기	유지보수·장애 대응을 우리 팀이	0원?

추천안과 그 이유까지 한 장에. 그런데 비용 칸은 가격표만 보고는 채울 수 없습니다.

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

02

잘 사기

가격표가 아니라, 영수증 전체를 본다.

READ THE FULL RECEIPT

가격표보다 긴 영수증.
총소유비용으로 비교합니다.

SECURITY RECEIPT

라이선스·서비스 사용료	+
수집·저장·분석·전송	+
연동·튜닝·유지보수 인력	+
교육·전환·종료 비용	+
TOTAL	**TCO**

라이선스가 무료여도 운영까지 무료는 아닙니다.

오픈소스의 유지보수 시간과
상용 제품의 도입·운영 시간을
같은 기준으로 비교합니다.

> 라이선스는
> **전체 비용의 일부입니다.**

SAME PRODUCT, DIFFERENT TCO

내부 인프라와 아키텍처에 따라 TCO도 달라집니다.

TCO (Total Cost of Ownership) · 도입부터 운영, 전환·종료까지 드는 전체 비용

INFRASTRUCTURE & ARCHITECTURE

우리 환경에서는 로그를 얼마나 수집하고 보관할까?

소스 · 수집량 · 보존 기간 · 분석 빈도 · 연동 대상

보안 효과	볼 수 있는 위협과 조사 범위
비용 변화	수집·저장·분석·전송 비용
운영 부담	알림 처리·규칙 튜닝·유지보수

같은 제품도 우리 환경에 따라 수집량·연동 범위·운영 공수가 달라집니다.

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

VALUE, NOT JUST PRICE

비용을 줄여야 한다면, 어디서 줄일까요?

판단 단위	확인할 질문	남길 근거
유지할 것	중요 위협에 꼭 필요한가?	시나리오별 커버리지
최적화할 것	중복 수집·불필요한 보존인가?	사용량·분석 빈도
다시 검증할 것	절감 뒤에도 탐지·조사가 되는가?	재현 테스트·운영 결과

아키텍처를 보지 않고 줄이면, 청구서와 함께 보이는 범위도 줄어듭니다.

03

잘 쓰기

기능 목록이 아니라, 운영 결과로 증명한다.

OPERATIONAL OUTCOME · MTTD / MTTR

"어떤 기능이 있나요?" 다음 질문.
얼마나 빨리 알아채고, 얼마나 빨리 조치했나요?

t_0 위협 발생 — t_1 탐지·진단 — t_2 조치 완료

MTTD 평균($t_1 - t_0$)

Mean Time To Detect

위협이 발생해서
실제 위협으로 탐지·진단하기까지

MTTR 평균($t_2 - t_1$)

Mean Time To Respond

탐지한 뒤 조치가 실제로 적용된 걸 확인하기까지

자동 대응 예시

조건 검증 권한·대상·예외 → **차단 조치** 키 비활성화·권한 제한 → **결과 확인** 실패 시 담당자 이관

함께 보는 지표

MTTD · MTTR + 조치 성공률 + 오탐 영향 + 중요 시나리오 커버리지

FROM THE SOURCE · NIST CSF 2.0

청사진과 현재 사이의 공백을 계속 확인합니다.

CSF CORE · APPENDIX A · p.15

Table 1. CSF 2.0 Core Function and Category names and identifiers

Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

ORGANIZATIONAL PROFILES · §3.1

현재 상태
Current Profile

…the Core outcomes that an organization is **currently achieving** (or attempting to achieve)…

목표 상태
Target Profile

…the **desired outcomes** that an organization has selected and prioritized…

공백 분석
Step 4

Conduct a **gap analysis** to identify and analyze the differences between the Current and Target Profiles…

실행 · 갱신
Step 5

Implement the action plan, and **update** the Organizational Profile.

"Given the importance of continual improvement, an organization can repeat these steps as often as needed."

NIST CSWP 29, The NIST Cybersecurity Framework (CSF) 2.0 (2024.02.26) · Table 1 p.15, §3.1 pp.6-7 원문 발췌 ↗

THE NEXT ITEM IN YOUR CART

AI 자동화도,
우리가 골라야 할 제품이라고 본다면?

고른다

권한과 데이터

무엇을 읽고, 어디까지 실행하게 둘까?

산다

전체 비용과 사람

추론·연동·검증 비용, 그리고 누가 이해하고 운영할까?

쓴다

실패와 책임

잘못된 조치는 누가 멈추고 되돌릴까?

**성급하게 AI로 자동화하거나 기존 업무를 대체하기보다,
잘 쓰던 팀이 더 잘 쓰게 돕는 쪽이 먼저가 아닐까요?**

SACR & Josh Trup, The Future of SOC Automation Platforms (2024) · 자동화 생태계 참고 ↗

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

YOUR SHOPPING LIST

잘 고르고.
잘 사고.
잘 쓰는 것도 실력이다.

직접 검증한 성분표로 고르고 · 영수증 전체로 값을 매기고 · 운영 결과로 증명하기

제품이 달라져도, 우리 환경에 필요한 이유와 전체 비용,
운영 결과를 설명할 수 있어야 합니다.

박건호 · GitHub: gunh0 · LinkedIn: gunh0902

THANK YOU FOR SHOPPING

감사합니다.

보안 제품을 잘 고르고, 잘 사고, 잘 쓰는 것도 실력이다

HYUNDAI AutoEver



Gunho Park (박건호) · Cloud Security Engineer

linkedin.com/in/gunh0902

OWASP

SECURITY RECEIPT

OWASP SEOUL · 2026.09.29

01 잘 고르기	기술검토
02 잘 사기	총소유비용
03 잘 쓰기	운영 결과

TOTAL PAID ✓

THANK YOU FOR SHOPPING

SOURCE LABELS

참고자료

[1] **Redefining CNAPP: A Complete Guide**

SACR & James Berthoty · 2024.09.12 / 마켓맵과 시장 모순(지출·만족, 기능 과잉, 도구 수)의 문제의식. 마켓맵 그림은 저자 원본을 출처 표기와 함께 사용

softwareanalyst.substack.com/p/redefining-cnapp-a-complete-guide ↗

[2] **The Future of SOC Automation Platforms**

SACR & Josh Trup · 2024.05.02 / 자동화 생태계의 변화 참고

softwareanalyst.io/reports/the-future-of-soc-automation-platforms ↗

[3] **NIST Cybersecurity Framework (CSF) 2.0**

NIST CSWP 29 · 2024.02.26 / Core의 Function·Category 표(Appendix A Table 1, p.15)와 Current·Target Profile, 공백 분석 절차(§3.1)

nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf ↗